

MODULE 42 · EXAM STRATEGY - ALL DOMAINS

Practice exam 3 of 4

20 questions, weighted toward detection and infrastructure. Several answers turn on a single clause.

QUESTIONS 20 PASS MARK 15 of 20 HOLD 9 seconds

A company must log every object-level read and write in one S3 bucket that holds cardholder data. It has 4,000 other buckets whose object-level activity it does not need, and CloudTrail data event charges are a stated concern.

Management events are already captured by an organization trail.

What should the company configure?

- ☐ A Enable S3 server access logging on the cardholder bucket
- ☐ B Enable data events for all S3 buckets and filter at query time
- ☐ C Add the bucket to the organization trail's management event selectors
- ☐ D A trail with advanced event selectors scoped to that bucket's ARN

◆ PAUSE AND DECIDE

What should the company configure?

- A

 S3 server access logging
Best-effort delivery with no guaranteed completeness or ordering, and it is not CloudTrail. Poor fit where an auditor wants a reliable record.
- B

 Data events for all buckets, filter later
You pay for every event ingested from 4,001 buckets. Filtering at query time controls what you read, not what you are billed for.
- C

 Management event selectors
Object-level reads and writes are data events, not management events. The selector type is the whole point.
- D

 Advanced event selectors scoped to the bucket ARN
Correct. Advanced event selectors let you include data events for a specific bucket ARN only, so you capture what you need and pay for nothing else.

DOMAIN 1

Data events are off by default and charged separately. Advanced event selectors are how you get precision without paying for everything.

A regulator requires a company to demonstrate that its CloudTrail logs have not been altered or deleted since they were written, including by the company's own security administrators.

Logs are delivered to a bucket in a dedicated Log Archive account.

Which combination should the company implement?

- | | |
|---|---|
| ☐ A SSE-KMS on the bucket, plus an SCP denying s3:DeleteObject | ☐ B CloudTrail log file integrity validation, plus S3 Object Lock in compliance mode on the archive bucket |
| ☐ C S3 versioning with MFA delete, plus CloudWatch alarms on deletion attempts | ☐ D CloudTrail Lake with a 10-year retention period |

◆ PAUSE AND DECIDE

Which combination should the company implement?

- A

 SSE-KMS plus an SCP
Encryption protects confidentiality, not integrity, and an SCP is a policy an administrator with the right access could change. Neither proves the files are unaltered.
- B

 Log file integrity validation plus Object Lock compliance mode
Correct. Integrity validation produces signed digest files proving the logs are unaltered; compliance mode means nobody, including root, can delete them.
- C

 Versioning with MFA delete plus alarms
Raises the cost of deletion rather than preventing it, and alarms report afterwards. A determined administrator with the MFA device is unaffected.
- D

 CloudTrail Lake with 10-year retention
A managed store with a retention period. It answers how long, not whether the records were tampered with.

DOMAIN 1

Two requirements – unaltered and undeletable – so two mechanisms. Integrity validation proves the first; compliance mode enforces the second.

A company with 12,000 S3 buckets wants ongoing visibility into which buckets contain personal data, at predictable cost, without scanning every object in every bucket every day. It also needs a one-off deep inspection of six buckets before an audit next month.

What should the company use?

- ☐ A Full Macie classification jobs across all buckets, scheduled daily
- ☐ B Inspector, configured to scan S3 objects for sensitive data
- ☐ C Macie automated sensitive data discovery for continuous coverage, plus targeted classification jobs for the six buckets
- ☐ D AWS Config rules evaluating bucket contents for personal data

◆ PAUSE AND DECIDE

What should the company use?

A Full daily jobs everywhere

Exactly what the requirement excludes. Scanning every object in 12,000 buckets daily is the unpredictable cost the question is written to avoid.

C Automated discovery plus targeted jobs

Correct. Automated sensitive data discovery samples continuously at predictable cost; a classification job gives the deep one-off inspection for six buckets.

B Inspector on S3 objects

Inspector finds software vulnerabilities in workloads and code. It does not classify data content.

D Config rules on bucket contents

Config evaluates resource configuration, not object contents. No Config rule can read what is inside a bucket.

DOMAIN 1

Two requirements, two Macie modes. Automated discovery is the broad sampling layer; a classification job is the deep dive.

A security team must be notified within one minute whenever an AWS Config rule changes a resource's compliance status to non-compliant, across 60 accounts, so an on-call engineer can triage.

Config is aggregated into a security account.

What should the team build?

- ☐ A An EventBridge rule matching Config Rules Compliance Change events, targeting SNS
- ☐ B A scheduled Lambda function polling the Config API every minute
- ☐ C A CloudWatch alarm on the Config compliance metric
- ☐ D A Security Hub CSPM insight filtered to non-compliant resources

◆ PAUSE AND DECIDE

What should the team build?

- A

 EventBridge rule on compliance change events
Correct. Config emits a Config Rules Compliance Change event on every status transition, so EventBridge delivers within seconds with nothing to run or maintain.
- B

 Lambda polling every minute
Rebuilds an event-driven mechanism as a polling one, in 60 accounts, with cost and failure modes attached.
- C

 A CloudWatch alarm on a metric
Aggregate metrics tell you counts changed, not which resource or which rule. An on-call engineer cannot triage from that.
- D

 A Security Hub insight
Insights are saved views for humans looking at a console. They do not push a notification within a minute.

DOMAIN 1

If a service emits an event for the thing you care about, do not build a poller for it.

A company is building its incident response capability. It wants documented, executable response procedures that an engineer can run consistently, and a place to track each incident's investigation items and their status.

The team is following the SCS-C03 exam guide's named services for this task.

Which pair should the company use?

- ☐ A AWS Incident Manager for tracking, with Lambda functions as runbooks
- ☐ B AWS Security Incident Response for both procedures and tracking
- ☐ C SSM Automation runbooks for executable procedures, and Systems Manager OpsCenter for tracking investigation items
- ☐ D Step Functions state machines for procedures, and Security Hub CSPM for tracking

◆ PAUSE AND DECIDE

Which pair should the company use?

- A

 Incident Manager plus Lambda runbooks
Incident Manager closed to new customers in November 2025, and the C03 guide does not name it. This is the C02-era answer.
- B

 AWS Security Incident Response
A real managed service, and it is not in the C03 in-scope service list. Plausible in practice, wrong for this exam.
- C

 SSM Automation runbooks plus OpsCenter
Correct. Skill 2.1.1 names OpsCenter for tracking investigation items, and SSM Automation documents are AWS's executable runbook mechanism.
- D

 Step Functions plus Security Hub
Both are real and used in response architectures. Neither is what the exam guide names for documenting procedures and tracking investigation items.

DOMAIN 2

The C03 guide names OpsCenter and never mentions Incident Manager. That change is worth knowing precisely.

A security team wants to verify end to end that a GuardDuty finding reaches its EventBridge rule, triggers the isolation runbook, pages the on-call engineer and creates a ticket, without waiting for a real compromise.

Production workloads must not be disrupted.

What should the team use?

- ☐ A AWS Fault Injection Service, injecting a simulated compromise
- ☐ B A penetration test against a production instance
- ☐ C Manually creating a finding through the GuardDuty API
- ☐ D GuardDuty sample findings

◆ PAUSE AND DECIDE

What should the team use?

A Fault Injection Service

FIS injects infrastructure faults – instance termination, latency, API errors. It does not simulate an attacker or generate security findings.

C Create a finding via the API

GuardDuty does not expose finding creation. Findings come from its own analysis, or from the sample findings feature.

B A penetration test in production

Would generate real findings and real disruption. The requirement explicitly excludes disrupting production.

D GuardDuty sample findings

Correct. Sample findings generate realistic findings of each type that flow through EventBridge exactly as real ones do, disrupting nothing.

DOMAIN 2

FIS tests whether the architecture survives failure. Sample findings test whether the response pipeline works.

An attacker with stolen credentials copied every object in a data bucket over itself using SSE-C with their own key, rendering the objects unreadable. The bucket has versioning enabled and Object Lock was never configured.

The team must restore access to the data.

What should the team do?

- ☐ A Contact AWS Support to recover the SSE-C key from CloudTrail
- ☐ B Restore the previous object versions, which are unaffected by the attacker's writes
- ☐ C Use the KMS key policy to decrypt the affected objects
- ☐ D Restore from the bucket's Object Lock retention copies

◆ PAUSE AND DECIDE

What should the team do?

- A

 Recover the key from CloudTrail
S3 never stores an SSE-C key and CloudTrail never records it. That is the whole design, and it is exactly why the attack works.
- C

 Use the KMS key policy
No KMS key is involved. SSE-C means the caller supplies the key on every request, which is the point of the attack.
- B

 Restore the previous versions
Correct. Writing a new object version does not alter earlier ones. Versioning is what turns this from unrecoverable into an inconvenience.
- D

 Object Lock retention copies
The question says Object Lock was never configured, and Object Lock protects versions rather than creating separate copies.

DOMAIN 2

SSE-C ransomware is unrecoverable without versioning, and merely annoying with it. That one setting is the difference.

An application tier scales between 4 and 90 instances. A database tier must accept connections on port 5432 from the application tier only. Instance addresses change constantly as the group scales.

The solution must require no updates when instances are replaced.

What should be configured?

- ☐ A A database security group rule allowing port 5432 from the application tier's security group ID
- ☐ B A managed prefix list containing the application subnet CIDRs, referenced by the database security group
- ☐ C A network ACL allowing port 5432 from the application subnet range
- ☐ D A Lambda function updating the database security group when instances launch or terminate

◆ PAUSE AND DECIDE

What should be configured?

- A

 Reference the application security group ID
Correct. A security group reference means membership, not addresses – every instance in that group is permitted, and replacements inherit it automatically.
- B

 A managed prefix list of subnet CIDRs
Permits anything in those subnets, including instances that are not part of the application tier. Broader than 'the application tier only'.
- C

 A NACL on the subnet range
Same over-permission as B, and stateless, so return traffic needs its own rule. NACLs are for blocking, not for tier-to-tier allow.
- D

 A Lambda updating rules on scaling events
Builds automation to replicate a feature that already exists, with rule-limit and failure risks attached.

DOMAIN 3

Security group referencing is membership-based. It is the only option here that survives every instance replacement untouched.

A company with 40 VPCs across three Regions must inspect and filter all outbound internet traffic against a domain allow-list, from one place, with consistent rules. Individual VPC owners must not be able to bypass the inspection.

The VPCs are already connected by Transit Gateway.

What should the company implement?

- ☐ A AWS Network Firewall in every VPC, managed independently by each team
- ☐ B A centralised inspection VPC with Network Firewall, routed through Transit Gateway, with rules deployed by Firewall Manager
- ☐ C Route 53 Resolver DNS Firewall with a domain allow-list in each VPC
- ☐ D A NAT gateway per VPC with security group rules restricting destinations

◆ PAUSE AND DECIDE

What should the company implement?

- A

 Network Firewall per VPC, team-managed
Independent management is exactly what the requirement forbids – 40 rule sets that drift, each editable by the team it constrains.
- B

 Centralised inspection VPC, Transit Gateway routing, Firewall Manager
Correct. One inspection point, routing enforced at the Transit Gateway so VPC owners cannot bypass it, and Firewall Manager keeps rules consistent centrally.
- C

 DNS Firewall allow-lists per VPC
Filters names only, so a hardcoded IP bypasses it entirely – and per-VPC configuration is again editable by the VPC owner.
- D

 NAT gateway plus security groups
Security groups permit by address and port, not by domain, and a NAT gateway inspects nothing. It also leaves each VPC in control.

DOMAIN 3

'From one place, and owners cannot bypass it' means the enforcement lives in the routing, not in each VPC.

An organisation must ensure every EC2 instance launched across 200 accounts requires IMDSv2, including in accounts created next year, and that non-compliant launches are prevented rather than remediated.

Teams manage their own launch templates and use a mixture of console, CLI and Terraform.

What should the organisation implement?

- ☐ A A Config rule with SSM Automation remediation setting instances to IMDSv2
- ☐ B Updating every team's launch template to require IMDSv2
- ☐ C Account and Region metadata defaults set to required, plus an SCP denying ec2:RunInstances when ec2:MetadataHttpTokens is not required
- ☐ D A proactive Control Tower control blocking non-compliant instance provisioning

◆ PAUSE AND DECIDE

What should the organisation implement?

- A

 Config rule with remediation
Corrective. The instance exists with IMDSv1 available until remediation runs, and the requirement says prevented rather than remediated.
- B

 Update every launch template
Depends on every team acting and on nobody creating a new template. It also does nothing for console or CLI launches outside a template.
- C

 Metadata defaults plus an SCP on `ec2:MetadataHttpTokens`
Correct. The default sets the safe behaviour, the SCP denies non-compliant launches at the API regardless of tool, and new accounts inherit both.
- D

 A proactive control
Proactive controls are CloudFormation hooks. This organisation launches by console, CLI and Terraform, so most launches never meet the hook.

DOMAIN 3

'A mixture of console, CLI and Terraform' eliminates the CloudFormation-only answer. Preventive at the API level is what survives.

A healthcare company builds a clinical summarisation feature on Amazon Bedrock. Patient data will appear in prompts. Security requires that prompt traffic never traverses the public internet, and that personal identifiers are removed from model responses before they reach clinicians.

The team needs both requirements met.

Which combination is correct?

- ☐ A A VPC interface endpoint for Bedrock, plus a Bedrock guardrail with sensitive information filters
- ☐ B A NAT gateway with restricted routes, plus Macie scanning the responses
- ☐ C Bedrock model invocation logging, plus CloudWatch Logs data protection on the log group
- ☐ D An IAM policy denying bedrock:InvokeModel from outside the VPC, plus Comprehend PII detection

◆ PAUSE AND DECIDE

Which combination is correct?

- A

 Interface endpoint plus guardrail sensitive information filters
Correct. PrivateLink keeps the traffic off the internet; guardrail sensitive information filters mask or block PII in prompts and responses.
- B

 NAT gateway plus Macie
A NAT gateway sends traffic out to the internet – the opposite of the requirement. Macie scans S3, not model responses.
- C

 Invocation logging plus log masking
Protects the logs, not the clinician's screen. Note also that guardrail-blocked content still appears in invocation logs in plain text.
- D

 IAM deny plus Comprehend
An IAM condition controls who may call, not the network path taken. Comprehend can detect PII, but it is a second service doing what a guardrail does inline.

DOMAIN 3

Two requirements, two controls: PrivateLink for the path, guardrails for the content. Neither one alone satisfies both.

A role carrying AdministratorAccess receives AccessDenied calling rds>DeleteDBInstance in eu-central-1. The CloudTrail event's errorMessage states the request was denied with an explicit deny in a service control policy.

An engineer runs the policy simulator against the role for that action; it reports Allowed.

What should the engineer do next?

- ☐ A Re-run the simulation specifying the resource ARN
- ☐ B Open a support case, since the simulator and CloudTrail disagree
- ☐ C Check the role's permissions boundary, which produces this message
- ☐ D Examine the SCPs applying to the account, which the error message has already named

◆ PAUSE AND DECIDE

What should the engineer do next?

A Re-run with the resource ARN

A reasonable simulator habit that does not address this. The message names an SCP, and a more precise simulation of the identity policy will not surface it.

C Check the permissions boundary

A boundary denies by being silent – an implicit deny. The message specifically says explicit deny in a service control policy.

B Raise a support case

They do not disagree. CloudTrail reports what happened; the simulator reports a hypothetical over the policies it evaluated.

D Examine the SCPs; the message named the type

Correct. The error message did the hard part. An explicit deny in an SCP beats AdministratorAccess, exactly as the evaluation model says.

DOMAIN 4

Read the errorMessage first. When it names a policy type, most of the investigation is already done.

Sixty on-premises servers must call AWS APIs. They currently use IAM user access keys stored in configuration files, which have not been rotated in two years. The company already operates its own certificate authority.

The solution must eliminate long-lived credentials on the servers.

What should the company implement?

- ☐ A An IAM user per server with access keys rotated automatically by Secrets Manager
- ☐ B IAM Identity Center permission sets assigned to service accounts
- ☐ C IAM Roles Anywhere, with a trust anchor referencing the company's certificate authority
- ☐ D A Cognito identity pool issuing credentials to the servers

◆ PAUSE AND DECIDE

What should the company implement?

- A

 IAM users with rotated keys
Rotation shortens the life of a long-lived credential without removing it. The requirement says eliminate.
- B

 Identity Center permission sets
Identity Center is built for human workforce access through a sign-in portal, not for unattended servers.
- C

 IAM Roles Anywhere with a trust anchor
Correct. Servers present an X.509 certificate from the existing CA and exchange it for temporary credentials - no long-lived keys anywhere.
- D

 A Cognito identity pool
Cognito serves application end users. It is not the mechanism for workloads outside AWS.

DOMAIN 4

'They already operate a certificate authority' is the enabling clause. Roles Anywhere needs a trust anchor, and they have one.

A company uses IAM Identity Center with permission sets assigned to groups. A compliance requirement states that no principal in the organisation, however granted, may create IAM users or access keys.

A security engineer argues that Identity Center is managed separately and cannot be constrained this way.

Which statement is correct?

- ☐ A A permission set provisions a real IAM role in the target account, so an SCP denying `iam:CreateUser` and `iam:CreateAccessKey` caps it like any other role
- ☐ B Identity Center sessions bypass SCPs and must be constrained inside the permission set
- ☐ C Only an RCP can constrain Identity Center sessions
- ☐ D The requirement can only be met by removing those actions from every permission set

◆ PAUSE AND DECIDE

Which statement is correct?

- A** A permission set is a real IAM role; an SCP caps it
Correct. Assignment provisions an AWSReservedSSO_ role in the target account, and every organisational ceiling applies to it exactly as to any other role.
- B** Identity Center bypasses SCPs
The engineer's misconception. There is no principal type that escapes an SCP in a member account.
- C** Only an RCP works
RCPs cap what may be done to resources. This requirement is about what principals may do, which is SCP territory.
- D** Edit every permission set
Would work today and relies on every future permission set being written correctly. 'However granted' asks for a ceiling, not a convention.

DOMAIN 4

A permission set is a template. The thing evaluated is an ordinary IAM role with an ugly name, and every ceiling applies to it.

A SaaS monitoring vendor asks a company to create a role the vendor can assume, and provides a unique identifier string to place in the role's trust policy condition.

A security reviewer asks why the vendor generates that value rather than the company.

What is the correct explanation?

- ☐ A AWS requires external IDs to be generated by the account that will assume the role
- ☐ B It is arbitrary; either party may generate it with equal effect
- ☐ C The company should generate it instead, and the vendor's request is a misconfiguration
- ☐ D The vendor generates it so each customer's value is unique and unpredictable, preventing one customer naming another's role and being confused-deputied into it

◆ PAUSE AND DECIDE

What is the correct explanation?

- A

 AWS requires it
AWS recommends it as the practice that makes the control effective. It is not enforced by the service.
- B

 Arbitrary; either party works
The dangerous answer. If a customer could choose their own value, they could choose one that matches another customer's.
- C

 The company should generate it
Inverts the control. A customer-chosen value can be guessed or copied, which is exactly the attack the external ID prevents.
- D

 Vendor-generated, unique and unpredictable per customer
Correct. The external ID defends the vendor's other customers – it stops customer A pointing the vendor at customer B's role.

DOMAIN 4

The external ID protects the vendor's other customers, not primarily you. That is why the vendor must generate it.

A defence contractor must satisfy a regulator that key material protecting classified data is never present within AWS infrastructure, and that the contractor can render the data unreadable unilaterally at any moment.

Applications must continue using ordinary AWS SDK calls with no code changes.

What should the contractor use?

- ☐ A A customer managed key with imported key material and a short expiry
- ☐ B An AWS KMS external key store, with key material in the contractor's own key manager
- ☐ C A CloudHSM key store backed by a dedicated CloudHSM cluster
- ☐ D Client-side encryption with keys held on-premises

◆ PAUSE AND DECIDE

What should the contractor use?

- A

 Imported key material with a short expiry
The strongest distractor. Expiry does give unilateral revocation – but imported material is imported into KMS, so it is present in AWS. Fails requirement one.
- C

 A CloudHSM key store
Single-tenant hardware the contractor controls – and it sits inside AWS infrastructure, which the requirement excludes explicitly.
- B

 An external key store
Correct. Material never enters AWS, every operation happens in the contractor's HSM, and the key still presents as an ordinary KMS ARN so SDK calls are unchanged.
- D

 Client-side encryption
Satisfies both security requirements and breaks the third: applications would need rewriting to encrypt and decrypt themselves.

DOMAIN 5

Three requirements, and each wrong option fails a different one. 'Never inside AWS' is the clause that picks XKS.

Analysts must read encrypted objects from a reporting bucket, which requires decryption under a customer managed key. The same key also protects other datasets, and analysts must not be able to call kms:Decrypt directly against arbitrary ciphertext. The team wants one control, without maintaining a list of object ARNs.

What should be added to the key policy?

- ☐ A An Allow for the analyst role conditioned on kms:ViaService matching the S3 endpoint in that Region
- ☐ B A Deny on kms:Decrypt for the analyst role, with an exception listing the reporting bucket's objects
- ☐ C An Allow conditioned on aws:SourceVpce matching the S3 gateway endpoint
- ☐ D A grant to the analyst role with an EncryptionContextEquals constraint on the bucket name

◆ PAUSE AND DECIDE

What should be added to the key policy?

- A

 Allow conditioned on kms:ViaService for S3
Correct. ViaService permits the key's use only when the request arrives through S3 acting for the principal, so a direct kms:Decrypt call is not permitted.
- B

 Deny with an object exception list
KMS policies do not evaluate S3 object ARNs, and the requirement rules out maintaining a list anyway.
- C

 Allow conditioned on aws:SourceVpce
Constrains the network path, not the calling service. An analyst inside that VPC could still call kms:Decrypt directly.
- D

 Grant with EncryptionContextEquals
The closest wrong answer – S3 does use the object ARN as encryption context. It scopes which objects, not which path, so direct Decrypt with the right context still works.

DOMAIN 5

'Through this service' and 'from this network' are different questions. ViaService answers the first.

Analysts query a Redshift table containing national identity numbers. Analysts must see only the last four digits; the fraud team must see full values. Both groups query the same tables with the same tools.

The company will not maintain duplicate views or a second copy of the data.

What should the company use?

- ☐ A S3 Object Lambda redacting values on read
- ☐ B A masked view for analysts and base-table access for the fraud team
- ☐ C Redshift dynamic data masking policies attached to the analyst and fraud roles
- ☐ D Macie automated sensitive data discovery on the Redshift cluster

◆ PAUSE AND DECIDE

What should the company use?

- A

 S3 Object Lambda
A genuine masking tool applied to the wrong data path. Object Lambda sits in the S3 GET path; these are Redshift queries.
- B

 A masked view plus base-table access
Explicitly ruled out – it is a duplicate object that must be kept in step as the schema evolves.
- C

 Redshift dynamic data masking per role
Correct. The same column returns different values depending on the querying role, with no duplicate view and no second copy.
- D

 Macie on Redshift
Macie discovers sensitive data in S3 and reports rather than changing what a query returns.

DOMAIN 5

'Same tables, same tools, no duplicates' describes dynamic data masking exactly.

A platform team must let 400 developers provision standardised, encrypted OpenSearch domains. Compliance requires that developers hold no OpenSearch permissions of their own, so they cannot create a domain outside the approved configuration. The team has an approved CloudFormation template.

What should the team implement?

- ☐ A Grant developers es:CreateDomain with conditions requiring encryption
- ☐ A Service Catalog product with a launch constraint, so Service Catalog assumes a launch role
- ☐ A service-managed StackSet deploying a domain per developer
- ☐ A CloudFormation Guard rule in the pipeline rejecting non-compliant templates

◆ PAUSE AND DECIDE

What should the team implement?

- A

 Grant permissions with conditions
Directly contradicts the requirement that developers hold no OpenSearch permissions. Conditions narrow a grant; they do not remove it.
- B

 Service Catalog product with a launch constraint
Correct. The launch role holds the permissions; developers hold only end-user catalogue access and cannot create a domain outside the product.
- C

 A StackSet per developer
StackSets push identical stacks on an administrator's schedule. Developers need self-service provisioning on demand.
- D

 A Guard rule in the pipeline
Validates templates that pass through the pipeline. It provisions nothing, and does not stop a developer with permissions acting outside it.

DOMAIN 6

'Developers hold no permissions of their own' selects the launch role pattern, which puts the permission in the role rather than the person.

A security team registers a dedicated account as the CloudFormation StackSets delegated administrator, so deployments do not run from the management account. The team then asks how to restrict that delegated administrator to deploying only into the sandbox OU. The management account owner wants assurance that a compromise there cannot reach production accounts.

What should the team be told?

- ☐ A Attach an SCP to the production OU denying the delegated administrator's role
- ☐ B Set account filters on each StackSet to exclude production accounts
- ☐ C Register a second delegated administrator scoped to the sandbox OU
- ☐ D Delegated administrators can deploy to any account in the organisation, and the management account cannot restrict them by OU

◆ PAUSE AND DECIDE

What should the team be told?

- A

An SCP on the production OU

Service-managed StackSet operations are performed by the management account, so an SCP on the production OU is not evaluating the delegated administrator's own principal.
- C

A second scoped delegated administrator

Delegated administration is not scoped by OU, so a second registration would carry the same organisation-wide reach.
- B

Account filters per StackSet

Filters scope one StackSet's targets. Whoever holds delegated administration can create another StackSet with different filters.
- D

They can deploy anywhere and cannot be restricted by OU

Correct, and AWS documents it. The delegated administrator is an organisation-wide privileged role and must be secured as one.

DOMAIN 6

The honest answer is that the restriction they want does not exist. The mitigation is to secure the role, not to scope it.

Scoring practice exam 3

- ◆ **Answer key:** D B C A C D B A B C A D C A D B A C B D.
- ◆ **Domains here:** Q1-4 detection, Q5-7 incident response, Q8-11 infrastructure, Q12-15 identity, Q16-18 data protection, Q19-20 governance.
- ◆ **Q5 and Q20 both have an honest answer** – one names a service the C03 guide dropped, the other says the control you want does not exist.
- ◆ **Q10 and Q16 are elimination questions:** each wrong option fails a different stated requirement. Count what each option covers.
- ◆ Compare your three scores by domain. A domain you have lost points in twice is where the next study session goes.

ON THE EXAM

Next: practice exam 4, the last one, weighted heavily toward governance.